CRISC Domain D - 100 Hard Questions with Advanced Options

Information Technology and Security - Expert Level Part 4

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

Every question is scenario-based and asks for the BEST, FIRST, or MOST appropriate action.
Every option is long and plausible; several are partly correct.
Think like a risk practitioner advising the business, not a technician.

Outline

1. 1. Enterprise Architecture
2. 2. IT Operations and Change Management
3. 3. Enterprise Resiliency
4. 4. Data Lifecycle Management
5. 5. SDLC and Emerging Technologies
6. 6. Information Security Principles

Q301: Missing Gap Analysis

Question

A risk practitioner reviewing an architecture program finds that the target-state design was approved without any gap analysis between the baseline and target architectures. What is the MOST significant risk?

- (A) The architecture board will be unable to meet again, because gap analysis is a mandatory precondition for scheduling any further review sessions
- (B) The target architecture will be technically invalid, because baseline documentation is always more reliable than any future-state design
- (C) Migration planning and funding will lack evidence of what must change, leading to underestimated cost, missed dependencies, and unmanaged transition risk
- (D) Vendors will be prevented from bidding, because requirements cannot be expressed to the market without a completed gap register

Q301: Explanation

Correct Answer: C

Why (C) is the best answer:

- Gap analysis links baseline to target state
- It drives sequencing, cost, and dependency decisions
- Without it, transition risk stays hidden

Critical Trap

A target state without gap analysis is an aspiration, not a plan.

Q302: Conflicting Principles

Question

Two approved principles conflict on a major initiative: "buy before build" and "minimize exposure of regulated data to third parties." The sponsor wants a SaaS product that stores regulated customer data. What should the risk practitioner recommend FIRST?

- (A) Apply whichever principle has the lowest implementation cost, since principles are ranked by their financial impact on the project
- (B) Escalate through architecture governance for an explicit, documented trade-off decision, with risk acceptance by the accountable business owner
- (C) Reject the SaaS product, because a conflict between principles is always resolved in favor of the more restrictive principle
- (D) Approve the product and add compensating controls after go-live, since principles are guidance and do not require formal governance review

Q302: Explanation

Correct Answer: B

Why (B) is the best answer:

- Conflicts need a governed decision, not a silent choice
- Trade-offs must be documented with rationale
- Risk acceptance belongs to the accountable owner

Critical Trap

Principle conflicts are resolved by governance, not by convenience.

Q303: Architecture Debt Prioritization

Question

An architecture team reports that tactical integrations built to meet deadlines now generate most of the incident volume. Leadership asks whether to fund remediation. Which analysis BEST supports a risk-based decision?

A. Compare the remediation cost with the original project budget to determine whether the earlier shortcuts were cost-effective

B. Rank integrations by age and retire the oldest first, since age is the strongest single predictor of failure and security weakness

C. Defer remediation until incident volume exceeds the threshold written into the integration vendor's support contract

D. Quantify the ongoing operational and security exposure of the debt against the cost and risk of remediation, then prioritize by business criticality

Q303: Explanation

Correct Answer: D

Why (D) is the best answer:

- Debt is a risk exposure, not just a cost
- Compare exposure against remediation effort
- Prioritize by business criticality

Critical Trap

Fund remediation by risk reduction, not by age or sunk cost.

Q304: Shadow IT Response

Question

Business units are adopting unsanctioned SaaS tools that process customer data. Blocking them outright would disrupt operations. What is the BEST architecture-aligned response?

A. Issue a policy prohibiting all unsanctioned tools and rely on disciplinary action to drive compliance across business units

B. Discover and assess the tools, bring high-value ones under governance through risk-based onboarding, and offer sanctioned alternatives for unmet needs

C. Allow continued use but require each business unit to self-certify the security of its tools once a year

D. Transfer accountability for the tools to the business units that procured them and remove them from the IT risk register

Q304: Explanation

Correct Answer: B

Why (B) is the best answer:

- Visibility comes before control
- Onboard valuable tools through risk-based review
- Address the unmet need that drove adoption

Critical Trap

Shadow IT is a symptom of unmet needs; prohibition alone drives it underground.

Q305: Identity Provider Dependency

Question

An architecture review finds that authentication for 40 critical applications depends on a single identity provider instance in one data center. What is the MOST appropriate recommendation?

- (A) Migrate all 40 applications to local authentication so that none depend on a shared service for sign-in
- (B) Assess the business impact of identity provider failure and design resilience, such as redundancy, failover, and break-glass access, proportionate to application criticality
- (C) Accept the risk, because commercial identity platforms are vendor-supported and therefore inherently highly available
- (D) Add monitoring to detect outages quickly, since detection alone satisfies the availability requirement of dependent applications

Q305: Explanation

Correct Answer: B

Why (B) is the best answer:

- A shared dependency creates correlated failure
- Resilience should match dependent criticality
- Break-glass access protects against lockout

Critical Trap

Shared services need resilience sized to what depends on them.

Q306: Proprietary Cloud Services

Question

A proposed cloud platform offers proprietary services that greatly reduce development time but make later migration costly. Which approach BEST addresses the lock-in risk?

- (A) Reject every proprietary service, since lock-in risk always outweighs the benefit of faster delivery
- (B) Rely on termination clauses in the contract, since legal exit rights remove the technical dependency
- (C) Evaluate exit cost and strategy during the decision, apply abstraction where the business case justifies it, and document residual lock-in as accepted risk
- (D) Adopt a multi-cloud design for every workload regardless of criticality to eliminate lock-in entirely

Q306: Explanation

Correct Answer: C

Why (C) is the best answer:

- Lock-in is a trade-off, not an automatic veto
- Plan the exit before committing
- Document residual risk for acceptance

Critical Trap

Manage lock-in through informed trade-offs, not blanket rules.

Q307: Undocumented APIs

Question

An organization adopting microservices discovers hundreds of undocumented internal APIs. Which risk should the practitioner treat as MOST critical from a governance standpoint?

- (A) Higher network latency from excessive service calls, which will degrade user experience across the platform
- (B) Unknown APIs cannot be inventoried, secured, or monitored, which leaves unmanaged attack surface and unclear ownership
- (C) Increased licensing cost, because each undocumented API will eventually require its own gateway license
- (D) Developers may rename endpoints, which would break backward compatibility for external partners

Q307: Explanation

Correct Answer: B

Why (B) is the best answer:

- You cannot protect what you cannot see
- Ownership of each API must be known
- Inventory enables monitoring and security testing

Critical Trap

Undocumented interfaces are unmanaged attack surface.

Q308: Expired Exception

Question

An architecture exception allowed a non-standard database for 12 months. The exception has now expired, but the application still runs on it. What should the risk practitioner do FIRST?

A. Allow the exception to roll over automatically, since the application remains operational and unchanged

B. Instruct the application team to migrate immediately, regardless of cost, dependencies, or business impact

C. Ensure the expired exception is reassessed, current risk is reflected in the risk register, and renewal or remediation is decided by the accountable authority

D. Close the exception record, since expiry of the approval period shows the matter has been resolved

Q308: Explanation

Correct Answer: C

Why (C) is the best answer:

- Expiry does not remove the underlying risk
- Reassess and update the risk register
- Decision authority renews or remediates

Critical Trap

An expired exception with a live deviation is an unmanaged risk.

Q309: Acquisition Integration

Question

After an acquisition, leadership wants fast integration of networks and applications. What should be the architecture risk priority?

- (A) Connect the networks immediately to realize synergies, and remediate security issues after integration is complete
- (B) Replace all acquired applications with the parent's standard stack before connecting any systems
- (C) Rely on the acquired company's compliance attestation, since it was reviewed during due diligence
- (D) Assess the acquired environment's security posture and dependencies before connecting it, then integrate in stages with defined trust boundaries

Q309: Explanation

Correct Answer: D

Why (D) is the best answer:

- Connecting unknown environments imports their risk
- Stage integration with trust boundaries
- Due diligence is not a substitute for technical assessment

Critical Trap

Assess before you connect.

Q310: Conflicting Customer Data

Question

Several departments keep their own copies of customer data with inconsistent definitions, causing reporting errors. Which architecture-level response BEST addresses the root cause?

A. Consolidate all departmental databases onto a single server so that duplicate copies disappear physically

B. Run a nightly reconciliation job that overwrites departmental data with the most recently updated version

C. Establish authoritative data sources and enterprise definitions with accountable data owners, supported by integration patterns that limit uncontrolled copies

D. Require each department to document its own definitions in a local data dictionary maintained by its team

Q310: Explanation

Correct Answer: C

Why (C) is the best answer:

- The root cause is lack of authority and definition
- Owners are accountable for each domain
- Integration patterns reduce uncontrolled copies

Critical Trap

Fix data conflicts with ownership and authoritative sources, not with copying.

Q311: Standards and Innovation

Question

Engineering teams complain that mandatory technology standards slow innovation. What is the BEST way for architecture governance to respond?

- (A) Remove standards for non-production environments, since production controls are sufficient to manage risk
- (B) Keep standards for critical controls while providing a defined, risk-based path to evaluate and onboard new technologies
- (C) Suspend standards for innovation projects until they reach production readiness, then enforce them
- (D) Retain all standards unchanged, since any flexibility inevitably increases risk to the enterprise

Q311: Explanation

Correct Answer: B

Why (B) is the best answer:

- Governance should enable as well as restrict
- Critical controls stay mandatory
- A clear onboarding path reduces workarounds

Critical Trap

Good governance offers a path for new technology, not only a wall.

Q312: Fragile Strategic Capability

Question

A capability heat map shows a capability rated critical to strategy but supported by an end-of-life application with little investment planned. What should the risk practitioner conclude?

- (A) The risk is low, because end-of-life applications are normally covered by extended support arrangements
- (B) The application must be decommissioned immediately, because end-of-life status always outweighs capability value
- (C) Strategic dependence on a fragile asset is a significant risk that requires prioritized investment or a mitigation plan
- (D) The heat map is flawed, because capabilities should not be rated by strategic importance

Q312: Explanation

Correct Answer: C

Why (C) is the best answer:

- High criticality plus weak support equals high risk
- Mitigation or investment must be planned
- Strategy depends on supporting assets

Critical Trap

Criticality without support is a risk hotspot.

Q313: Reference Architecture Deviation

Question

A project team deviates from the approved reference architecture to meet a deadline, claiming equivalent controls. What is the BEST way to validate the claim?

- (A) Accept the claim, because the project manager is accountable for delivery and schedule risk
- (B) Require full adoption of the reference architecture without considering the control objectives the team cites
- (C) Ask the vendor who supplied the components to certify that the design is equivalent
- (D) Have architecture or security review the deviation against the control objectives the reference architecture satisfies, and document the outcome

Q313: Explanation

Correct Answer: D

Why (D) is the best answer:

- Equivalence must be demonstrated, not asserted
- Compare against control objectives
- Document the review outcome

Critical Trap

A claim of equivalent controls needs independent validation.

Q314: Cloud-First Strategy

Question

The CIO announces a "cloud-first" strategy. Which action BEST ensures that risk is considered in its implementation?

- (A) Embed risk criteria in workload placement decisions, such as data sensitivity, regulatory constraints, and exit feasibility
- (B) Migrate low-risk workloads first and postpone any risk assessment until high-risk workloads are considered
- (C) Delegate cloud risk decisions to the provider through the shared responsibility model
- (D) Require all business units to adopt cloud by a fixed date to ensure a consistent approach

Q314: Explanation

Correct Answer: A

Why (A) is the best answer:

- Strategy needs decision criteria
- Placement depends on data and regulation
- Shared responsibility does not transfer accountability

Critical Trap

Cloud-first still needs risk-based placement.

Q315: Tight Coupling

Question

A proposed architecture uses tightly coupled components to reduce cost. What risk should the practitioner highlight?

- (A) Tight coupling increases the likelihood that one failure cascades across components, reducing resilience and making change harder to isolate
- (B) Tight coupling prevents scalability, because coupled components can never be deployed on separate servers
- (C) Tightly coupled systems cannot be monitored, because telemetry requires loosely coupled interfaces
- (D) Cost optimization is not an architecture concern and should not influence design decisions

Q315: Explanation

Correct Answer: A

Why (A) is the best answer:

- Coupling spreads failures
- Changes become harder to isolate
- Cost savings must be weighed against resilience

Critical Trap

Efficiency gained through coupling is paid for in fragility.

Q316: Stale Architecture Repository

Question

A review finds the enterprise architecture repository is largely out of date. What is the MOST significant implication for risk management?

- (A) Audit findings will increase, since documentation deficiencies are always scored as high severity
- (B) Risk assessments and impact analyses based on inaccurate architecture information may misjudge dependencies and exposure
- (C) Architecture staff will lose motivation, reducing the quality of future designs
- (D) The repository can be disregarded, because operational teams already hold accurate tacit knowledge

Q316: Explanation

Correct Answer: B

Why (B) is the best answer:

- Risk analysis relies on accurate dependency data
- Stale data leads to wrong impact conclusions
- Tacit knowledge is not auditable or scalable

Critical Trap

Outdated architecture data produces unreliable risk conclusions.

Q317: Governance Effectiveness

Question

How can the risk practitioner BEST determine whether architecture governance is effective?

- A. Assess whether the process consistently influences decisions, for example exceptions are tracked, deviations are remediated, and outcomes align with principles
- B. Count the number of architecture review meetings held each quarter
- C. Measure the number of projects approved without conditions, since that indicates alignment
- D. Verify that all architecture documents are stored in the repository, whether or not they are used

Q317: Explanation

Correct Answer: A

Why (A) is the best answer:

- Effectiveness is shown by influence on decisions
- Track exceptions and remediation
- Activity counts are not outcomes

Critical Trap

Measure outcomes of governance, not its activity.

Q318: Unapproved Emergency Change

Question

A critical outage required an emergency change. The change manager was unavailable and an engineer deployed the fix under verbal approval. What is the MOST important follow-up?

- (A) Retroactively review and document the change through the emergency change process, including approval, testing evidence, and post-implementation validation
- (B) Take no further action, since the outage was resolved and the speed of response was justified
- (C) Revert the change at once to restore the prior state, and then process it through the normal procedure
- (D) Discipline the engineer for bypassing approval and treat the matter as closed

Q318: Explanation

Correct Answer: A

Why (A) is the best answer:

- Emergency changes still need records
- Approval and evidence are captured after the event
- Validate that the fix did not introduce new risk

Critical Trap

Emergency does not mean undocumented.

Q319: Rubber-Stamp CAB

Question

A change advisory board approves 98 percent of changes, while change-related incidents are rising. What should the risk practitioner investigate FIRST?

- (A) Whether the board receives sufficient risk and impact information and challenges changes rigorously, or approves as a formality
- (B) Whether the board should meet more often to reduce its backlog of pending requests
- (C) Whether membership should be limited to IT staff so that decisions are faster
- (D) Whether incidents are being misclassified, since a high approval rate indicates good change quality

Q319: Explanation

Correct Answer: A

Why (A) is the best answer:

- Approval rate alone says little
- Look at the quality of information reviewed
- Challenge and testing evidence matter

Critical Trap

A board that approves everything is not a control.

Q320: Developer Deploys to Production

Question

A developer can deploy their own code to production in an organization that requires change approval. If segregation cannot be fully achieved, which is the BEST compensating control?

- (A) A manager's informal confirmation that the developer is trustworthy and experienced
- (B) Independent review of deployment logs against approved change records, performed by someone other than the deployer
- (C) Quarterly security awareness training that covers secure deployment practices
- (D) A policy statement reminding developers that unapproved code must not be deployed

Q320: Explanation

Correct Answer: B

Why (B) is the best answer:

- Compensating controls must detect misuse
- Independence is essential
- Reconcile deployments to approvals

Critical Trap

A compensating control needs independent detection, not trust.

Q321: Inaccurate CMDB

Question

An audit finds the CMDB is accurate for only 60 percent of critical assets. What is the MOST significant risk?

A. Asset depreciation will be misreported in the financial statements

B. Software licensing costs will rise, because vendors can audit the CMDB for discrepancies

C. Incident, change, and vulnerability decisions will rely on incomplete dependency and ownership data, causing misjudged impact

D. IT staff will be unable to access configuration management tools during incidents

Q321: Explanation

Correct Answer: C

Why (C) is the best answer:

- CMDB supports many operational processes
- Poor data misleads impact assessment
- Ownership gaps delay response

Critical Trap

A weak CMDB weakens every process that depends on it.

Q322: Unpatchable Legacy System

Question

A business-critical system cannot be patched because the vendor no longer supports it, and a high-severity vulnerability is being exploited in the wild. What is the BEST response?

- (A) Accept the vulnerability, because unsupported systems cannot be remediated in any way
- (B) Implement compensating controls such as isolation, access restriction, and enhanced monitoring, document risk acceptance, and plan replacement
- (C) Shut down the system immediately regardless of its business impact
- (D) Apply a patch from a public forum that claims to fix the flaw, since it is the only option available

Q322: Explanation

Correct Answer: B

Why (B) is the best answer:

- Isolate and monitor the exposed system
- Document acceptance by the accountable owner
- Plan replacement of unsupported technology

Critical Trap

If you cannot patch, you must contain.

Q323: Recurring Incidents

Question

Incidents of the same type recur monthly and are each resolved quickly by the service desk. What does this MOST likely indicate?

A. Problem management is ineffective, because root causes are not being identified and eliminated

B. Incident management is working well, since each incident is resolved within the SLA

C. The service desk needs additional staff to reduce recurrence

D. The incident classification scheme should be simplified to reduce repeated tickets

Q323: Explanation

Correct Answer: A

Why (A) is the best answer:

- Fast fixes can hide systemic causes
- Problem management targets root cause
- Recurrence signals a process gap

Critical Trap

Quick resolution of repeat incidents hides a problem-management failure.

Q324: SLA Met but Users Unhappy

Question

A provider consistently meets its SLA availability targets, yet business users complain about poor performance. What is the BEST explanation?

A. SLA metrics may not reflect the business-relevant user experience, such as measuring server uptime rather than transaction performance

B. Users are exaggerating, since SLA metrics are objective and verified

C. The SLA is too strict and should be relaxed to match what users realistically expect

D. The provider should be penalized regardless, because complaints indicate a breach

Q324: Explanation

Correct Answer: A

Why (A) is the best answer:

- Metrics must reflect business outcomes
- Uptime is not the same as usable service
- Revisit SLA measures with the business

Critical Trap

Meeting the SLA is not the same as meeting the need.

Q325: Peak Season Failure

Question

A retailer's e-commerce platform failed in peak season despite monthly capacity reports showing 60 percent average utilization. What is the MOST likely gap?

- (A) Capacity planning based on average utilization did not model peak demand or growth scenarios
- (B) Capacity reports should have been reviewed weekly rather than monthly
- (C) Servers should have been sized to run at 100 percent utilization targets
- (D) Capacity planning is the cloud provider's responsibility under any deployment model

Q325: Explanation

Correct Answer: A

Why (A) is the best answer:

- Averages hide peaks
- Model growth and seasonal scenarios
- Plan for demand, not for history

Critical Trap

Plan capacity for peaks, not averages.

Q326: Untested Rollback

Question

A release process has no tested rollback procedure. A deployment fails and takes hours to reverse. Which control improvement is MOST appropriate?

A. Prohibit deployments during business hours so failures affect fewer users

B. Require documented and tested rollback plans as an approval criterion, validated in pre-production

C. Increase the number of approvers required on every release

D. Require all releases to be deployed by the most senior engineers

Q326: Explanation

Correct Answer: B

Why (B) is the best answer:

- Rollback is a recovery control for change
- It must be tested before approval
- Approval criteria enforce discipline

Critical Trap

An untested rollback plan is only a hope.

Q327: Alert Fatigue

Question

Security operations receive thousands of alerts daily and analysts routinely ignore them. What is the BEST way to improve detection effectiveness?

- A Disable all low-severity alerts across every system to cut volume
- B Hire additional analysts so that every alert can be reviewed manually
- C Outsource alert review to a provider without changing the existing alert rules
- D Tune and prioritize alerts using risk-based use cases, thresholds, and context so analysts focus on high-fidelity events

Q327: Explanation

Correct Answer: D

Why (D) is the best answer:

- Noise hides real incidents
- Tune with risk-based use cases
- Add context to improve fidelity

Critical Trap

More alerts are not better detection.

Q328: Shared Admin Accounts

Question

A managed service provider administers production systems using shared privileged accounts. What is the PRIMARY risk?

- (A) Password complexity cannot be enforced on shared accounts, which makes brute-force attacks the primary exposure from this arrangement
- (B) Lack of individual accountability and inability to attribute actions, increasing the risk of undetected misuse
- (C) Provider staff will be unable to perform emergency changes, because shared accounts are blocked by most change management tools
- (D) Contractual liability will shift to the organization, because shared credential use is treated as customer-approved access under standard service terms

Q328: Explanation

Correct Answer: B

Why (B) is the best answer:

- Shared accounts prevent attribution
- Misuse becomes hard to detect
- Use named accounts with PAM

Critical Trap

Shared credentials destroy accountability.

Q329: Reliable Asset Inventory

Question

Which is the MOST reliable approach to maintaining an accurate hardware and software inventory?

- A Conduct an annual manual count performed by IT staff
- B Ask department heads to email lists of the assets they use
- C Rely on purchase orders alone as the source of truth
- D Combine automated discovery with reconciliation to procurement and ownership records, and investigate discrepancies

Q329: Explanation

Correct Answer: D

Why (D) is the best answer:

- Automated discovery finds the unknown
- Reconcile with procurement and owners
- Discrepancies reveal shadow assets

Critical Trap

Inventory accuracy needs discovery plus reconciliation.

Q330: Pre-Approved Standard Changes

Question

A DevOps team wants to pre-approve frequent low-risk deployments to avoid CAB delays. What is the BEST risk-informed approach?

A. Exempt DevOps teams from change management entirely, since they own their deployments and are accountable for the results

B. Define standard changes with clear criteria, automated testing and controls, and periodic review of outcomes to confirm they remain low risk

C. Pre-approve all changes below a defined cost threshold, since low-cost changes carry proportionately low risk

D. Allow teams to classify any change as standard without documented criteria, provided the team lead agrees afterward

Q330: Explanation

Correct Answer: B

Why (B) is the best answer:

- Pre-approval needs defined criteria
- Automation provides control evidence
- Review outcomes to validate low risk

Critical Trap

Speed is gained through controlled standardization, not exemption.

Q331: Skipped Post-Implementation Reviews

Question

Post-implementation reviews are skipped for most changes. What is the BEST justification for reinstating them?

- (A) They verify that intended outcomes and controls were achieved, capture lessons learned, and reveal unexpected or unauthorized side effects
- (B) They satisfy a regulatory requirement that applies to all changes without exception
- (C) They allow IT leadership to assign accountability for failed changes and apply performance penalties to the responsible teams
- (D) They replace the need for testing before deployment by validating each change in the live environment instead

Q331: Explanation

Correct Answer: A

Why (A) is the best answer:

- Confirm objectives and controls were met
- Capture lessons for future changes
- Detect unintended effects

Critical Trap

Reviews close the change loop.

Q332: Monitoring Coverage

Question

Which situation represents the greatest operational risk related to monitoring?

A. Monitoring dashboards differ in layout and color across teams, which prevents consistent interpretation of system status during incidents

B. Monitoring data is retained longer than operational needs require, increasing storage cost beyond what the business case approved

C. Non-production systems are not monitored in real time, which leaves development environments without immediate failure alerts

D. Critical systems are monitored for availability but not for security-relevant events or performance degradation

Q332: Explanation

Correct Answer: D

Why (D) is the best answer:

- Coverage must match risk
- Availability alone misses degradation
- Security events need visibility

Critical Trap

Monitor what matters, not just what is easy.

Q333: Silent Batch Failure

Question

A batch job failed silently over a weekend, causing incorrect financial reports. Which control improvement is MOST appropriate?

- (A) Run batch jobs only during business hours so failures are noticed sooner
- (B) Require the CFO to manually review all report outputs
- (C) Replace the scheduling tool with a different vendor's product
- (D) Implement job monitoring with automated failure alerting, escalation, and reconciliation checks on outputs

Q333: Explanation

Correct Answer: D

Why (D) is the best answer:

- Failures must generate alerts
- Escalation ensures response
- Reconcile outputs to detect errors

Critical Trap

A failure nobody sees is a control gap.

Q334: Missed Escalation

Question

A major incident exceeded its expected resolution time, but the incident manager never escalated to senior management. What is the MOST likely root cause to examine?

- (A) Insufficient technical skill in the resolver team, which delayed diagnosis and made escalation seem unnecessary
- (B) Excessive reliance on automated triage tools, which suppressed the alerts that would otherwise have prompted escalation
- (C) Lack of interest in operational issues among senior management, which discouraged the incident manager from raising concerns
- (D) Absence of clear escalation criteria and thresholds based on impact and duration in the incident management process

Q334: Explanation

Correct Answer: D

Why (D) is the best answer:

- Escalation needs defined triggers
- Impact and duration drive thresholds
- Process gaps beat blaming individuals

Critical Trap

Without triggers, escalation depends on judgment under pressure.

Q335: Cloud Console Changes

Question

Operations teams lack visibility into configuration changes made through cloud management consoles. What is the BEST control?

- (A) Permanently disable console access for all staff and require every change to go through a ticket handled by a single administrator
- (B) Rely on provider-level logs for audit purposes, without a defined process to review or alert on them
- (C) Enforce infrastructure as code with change logging, and detect and alert on drift from approved configuration
- (D) Require staff to notify the team by email after each console change so that changes can be recorded manually

Q335: Explanation

Correct Answer: C

Why (C) is the best answer:

- Code-driven changes are reviewable
- Drift detection finds unapproved changes
- Logs must be monitored, not just kept

Critical Trap

Controlled cloud change comes from code and drift detection.

Q336: RTO Versus Capability

Question

A BIA sets an RTO of 4 hours for a process, but the supporting application has a documented recovery time of 12 hours. What is the BEST action?

A. Address the gap by improving recovery capability or having the business formally reassess and accept the risk based on impact

B. Update the BIA to reflect the 12-hour recovery time as the new RTO

C. Take no action, since a DR plan exists and is documented

D. Move the process to a different application without further analysis

Q336: Explanation

Correct Answer: A

Why (A) is the best answer:

- A gap between need and capability is a risk
- Fix capability or formally accept risk
- Do not rewrite requirements to fit capability

Critical Trap

Do not change the requirement to hide the gap.

Q337: RPO Mismatch

Question

A system replicates data to the DR site every 6 hours, while the business states it can tolerate at most 1 hour of data loss. Which statement is correct?

A. The RTO is violated because replication occurs too infrequently

B. The design is acceptable, because RPO applies only to tape backups

C. The replication interval does not meet the RPO, so the solution must be redesigned or the shortfall formally accepted

D. The MTPD must be extended to 6 hours to match the replication interval

Q337: Explanation

Correct Answer: C

Why (C) is the best answer:

- RPO defines tolerable data loss
- Replication interval must be at or below the RPO
- Shortfall requires a decision

Critical Trap

RPO is about data loss, RTO is about time.

Q338: RTO and MTPD

Question

Which relationship between RTO and MTPD is MOST appropriate?

A. RTO is shorter than MTPD, leaving margin before unacceptable impact occurs
B. RTO equals MTPD, because any margin implies wasted recovery investment
C. RTO exceeds MTPD, because RTO measures only technical recovery effort
D. They are unrelated, because they are defined for different audiences

Q338: Explanation

Correct Answer: A

Why (A) is the best answer:

- MTPD is the limit of tolerable outage
- RTO is the target within that limit
- Margin allows for recovery variability

Critical Trap

RTO must fall inside MTPD.

Q339: Unrealistic DR Test

Question

A DR test was announced two weeks in advance, used the best staff, and restored only non-critical systems. What is the MOST significant limitation?

- A The test was too short to evaluate the recovery procedures properly
- B The test does not give reliable assurance that critical systems can be recovered under realistic conditions
- C Using the best staff violates segregation of duties requirements
- D Advance announcement of a DR test is a regulatory violation

Q339: Explanation

Correct Answer: B

Why (B) is the best answer:

- Tests must reflect real conditions
- Critical systems must be included
- Surprise and varied staffing build confidence

Critical Trap

A test that avoids the hard parts proves little.

Q340: Ransomware and Backups

Question

Following a ransomware event, backups were also encrypted because they were reachable from the production domain. Which control BEST addresses this?

A. Immutable or offline backups with separate credentials and tested restoration

B. Increase backup frequency to every hour, writing to the same repository so that recovery points are as recent as possible

C. Apply stronger encryption to the backup files so that attackers cannot read the data even if they can reach it

D. Extend backup retention to twelve months so that older copies exist if recent copies are affected

Q340: Explanation

Correct Answer: A

Why (A) is the best answer:

- Backups must be isolated from production
- Immutability prevents tampering
- Restoration must be tested

Critical Trap

Backups reachable by attackers are not a recovery plan.

Q341: Single Region SLA

Question

A critical SaaS application is hosted in a single cloud region, and the provider's SLA guarantees 99.9 percent availability. What is the BEST risk consideration?

A. SLA credits do not restore operations, so the organization must assess whether regional failure fits within its impact tolerance and plan accordingly

B. The SLA transfers all availability risk to the provider

C. A 99.9 percent SLA is equivalent to no unplanned downtime

D. A single region is always more resilient than multi-region

Q341: Explanation

Correct Answer: A

Why (A) is the best answer:

- SLA compensates but does not recover
- Compare outage risk with tolerance
- Plan for regional failure where needed

Critical Trap

SLAs compensate for outages; they do not prevent them.

Q342: Supplier Without BCP

Question

A business continuity plan assumes the availability of a critical supplier that has no continuity plan of its own. What is the BEST response?

- (A) Remove the dependency from the plan and document it as out of scope, since the supplier's resilience is outside the organization's control
- (B) Accept the supplier's verbal assurance of continuity, since the supplier has an established reputation and a long relationship with the organization
- (C) Transfer the risk to the supplier through contract wording alone, and consider the matter closed once the contract is signed
- (D) Assess supplier resilience, require or evaluate continuity capability, and develop alternatives or contingencies for the dependency

Q342: Explanation

Correct Answer: D

Why (D) is the best answer:

- Dependencies must be assessed
- Develop contingencies
- Contracts do not guarantee recovery

Critical Trap

A dependency you cannot verify is a risk you own.

Q343: Communication Failure in Exercise

Question

In a tabletop exercise, technical recovery went well, but communications to customers and regulators were delayed and inconsistent. What is the MOST appropriate improvement?

A. Add more technical staff to the response team so that recovery work is completed sooner and communication can follow

B. Remove external communications from the plan to avoid inconsistent messaging, and handle them ad hoc through executives

C. Reserve all communications for legal counsel without defined timing, so that every statement is reviewed before release

D. Define communication roles, templates, and approval paths in the plan and rehearse them

Q343: Explanation

Correct Answer: D

Why (D) is the best answer:

- Communication is part of recovery
- Pre-approved templates save time
- Rehearsal exposes delays

Critical Trap

Recovery includes communication.

Q344: Outdated BCP

Question

A BCP was last updated three years ago, although significant organizational and technology changes have occurred. What is the PRIMARY risk?

- A The plan may no longer reflect critical processes, dependencies, and contacts, making it ineffective in a real event
- B Auditors will impose a financial penalty, because regulations require continuity plans to be rewritten every year
- C The plan will become too detailed for executives to use, reducing the likelihood that decision makers will read it
- D Insurance coverage will lapse automatically, because insurers require evidence of annual plan revisions

Q344: Explanation

Correct Answer: A

Why (A) is the best answer:

- Plans must follow organizational change
- Contacts and dependencies change
- Review on a schedule and after major changes

Critical Trap

A plan that does not match reality will fail when needed.

Q345: Recovery Sequencing

Question

During DR planning, several applications claim to be Tier 1. What should determine recovery sequencing?

- (A) The seniority and influence of each application owner, since senior owners are best placed to judge their own priority
- (B) The technical complexity of each application, so that the simplest systems are restored first to show quick progress
- (C) BIA results, including dependencies between applications and shared infrastructure
- (D) The order in which the applications were deployed, because older systems usually underpin newer ones

Q345: Explanation

Correct Answer: C

Why (C) is the best answer:

- Business impact sets priority
- Dependencies determine order
- Foundation services recover first

Critical Trap

Sequence by business impact and dependency, not by politics.

Q346: Untested Restores

Question

Backups complete successfully every night, but restoration has never been tested. What is the BEST assessment?

A. The control is effective, because job completion is verified daily and failures are corrected by the backup team

B. Restoration testing is optional where backups are encrypted, since encryption already assures integrity and availability

C. Backup completion does not demonstrate recoverability, so periodic restoration tests are required

D. Testing can be replaced by increasing backup frequency, since more recovery points reduce the need to verify restores

Q346: Explanation

Correct Answer: C

Why (C) is the best answer:

- Success status is not proof of restore
- Test restores regularly
- Frequency does not equal recoverability

Critical Trap

A backup is only as good as its last successful restore.

Q347: Active-Active Assumption

Question

Management proposes active-active data centers to guarantee zero downtime. Which risk should the practitioner highlight?

- (A) Active-active designs cannot meet recovery time objectives, because switching traffic between sites always takes longer than restoring from backup
- (B) Shared logical failures, such as bad deployments, data corruption, or misconfiguration, can propagate to both sites simultaneously
- (C) Cost makes active-active unsuitable for every critical application, so asynchronous replication is always the better choice
- (D) Both sites will always be affected by the same physical disaster, because active-active requires them to be in the same metropolitan area

Q347: Explanation

Correct Answer: B

Why (B) is the best answer:

- Replication copies mistakes too
- Logical failures affect both sites
- Backups and change control are still needed

Critical Trap

Redundancy protects against hardware failure, not against bad changes.

Q348: Concentration Risk

Question

Many critical functions rely on a single cloud provider and a single DNS service. Which term BEST describes this risk?

A. Concentration risk, where one provider failure could disrupt multiple critical services at once

B. Residual risk, because the dependency remains after existing controls and redundancy have been applied

C. Inherent risk, because the dependency exists before any controls are considered and is determined by the business model

D. Risk appetite, because the board has chosen to rely on a small number of providers to simplify management

Q348: Explanation

Correct Answer: A

Why (A) is the best answer:

- Many services share one dependency
- A single failure creates broad impact
- Diversify or build contingency

Critical Trap

One dependency, many failures.

Q349: Impact Tolerance

Question

Regulators require firms to define impact tolerances for important business services. How does impact tolerance differ from RTO?

A. Impact tolerance is a technical metric measured by IT, expressing how quickly infrastructure must be restored after failure

B. Impact tolerance replaces the BIA, because it gives a single maximum disruption figure for the entire organization

C. Impact tolerance is determined by service vendors in the SLA, which sets the limit of disruption customers must accept

D. Impact tolerance defines the maximum disruption of a business service the organization can withstand, independent of the technical recovery design

Q349: Explanation

Correct Answer: D

Why (D) is the best answer:

- Tolerance is business-service focused
- It sets the limit of acceptable harm
- Technical design must meet it

Critical Trap

Impact tolerance is a business limit, not a technical target.

Q350: People and Site Dependencies

Question

A BCP focuses on IT recovery but assumes staff can reach alternate sites. A regional event prevents travel. What gap does this show?

- (A) Inadequate backup frequency, which prevented timely restoration of data at the alternate site
- (B) Insufficient firewall capacity at the alternate site, which slowed access after failover
- (C) Insufficient consideration of people and workspace dependencies and remote work capability
- (D) Excessive involvement of vendors in the response, which reduced the organization's control over recovery decisions

Q350: Explanation

Correct Answer: C

Why (C) is the best answer:

- Recovery depends on people
- Alternate access must be tested
- Plan beyond technology

Critical Trap

Continuity includes people and places, not just systems.

Q351: Restoring After Ransomware

Question

After a ransomware attack, the team wants to restore the latest backup immediately. What should be done FIRST?

- (A) Restore the latest backup immediately to minimize downtime, and run the investigation in parallel once systems are back
- (B) Pay the ransom to obtain the decryption key quickly, since this is usually faster than restoring from backups
- (C) Rebuild all systems from scratch before confirming scope, so that nothing from the compromised environment remains
- (D) Contain the threat and identify a clean restore point to avoid reintroducing the malware

Q351: Explanation

Correct Answer: D

Why (D) is the best answer:

- Contain before restoring
- Choose a verified clean restore point
- Restoring infected data re-infects

Critical Trap

Speed without containment repeats the incident.

Q352: DR Test Frequency

Question

Which factor should MOST influence the frequency and depth of DR testing for a system?

- A The cost of the DR site, since expensive recovery environments should be tested less often to control operating expense
- B The vendor's recommended schedule, since the vendor best understands how its own recovery features should be verified
- C Criticality of supported processes, rate of change in the environment, and previous test results
- D The number of users with access to the system, since a larger user base creates more recovery complexity

Q352: Explanation

Correct Answer: C

Why (C) is the best answer:

- Test more where impact is greater
- Change increases test need
- Past failures drive deeper testing

Critical Trap

Test in proportion to risk.

Q353: Overcomplicated Classification

Question

Data classification is applied inconsistently because users find a seven-level scheme too complex. What is the BEST improvement?

A. Mandate disciplinary action for any misclassification, so that users treat the scheme seriously

B. Increase the number of levels so that each data type can be classified with greater precision

C. Simplify the scheme to a few clear levels with handling rules and examples, supported by training and automated labeling

D. Classify all data at the highest level so that users do not need to exercise judgment

Q353: Explanation

Correct Answer: C

Why (C) is the best answer:

- Usability drives adherence
- Handling rules must be clear
- Automation reduces reliance on users

Critical Trap

A scheme that people cannot use is not a control.

Q354: Legal Hold

Question

A retention policy requires deletion of emails after 3 years, but the organization receives notice of litigation involving older emails. What should happen?

- (A) Continue deletion according to policy, since the retention schedule is the approved procedure and avoids storing excess data
- (B) Move the relevant emails to the personal storage of the custodians, so that organizational systems still comply with the retention policy
- (C) Delete the emails as scheduled but retain a summary document describing their content for use in the litigation
- (D) Suspend deletion of relevant data under a legal hold managed by legal counsel

Q354: Explanation

Correct Answer: D

Why (D) is the best answer:

- Legal obligations override routine deletion
- Legal counsel directs the hold
- Destroying evidence creates liability

Critical Trap

A legal hold overrides the retention schedule.

Q355: Collecting Just in Case

Question

A project proposes collecting additional customer attributes "in case they are useful later." Which principle is MOST relevant?

- (A) Data minimization: collect only data necessary for a defined, legitimate purpose
- (B) Data redundancy: retain multiple copies of each attribute so that future analytical needs can be met without recollection
- (C) Data portability: allow customers to move their data so that additional attributes can be reused across services
- (D) Data availability: keep all collected attributes online and accessible so that future projects can use them without delay

Q355: Explanation

Correct Answer: A

Why (A) is the best answer:

- Collect only what is needed
- Purpose must be defined
- Excess data is excess risk

Critical Trap

Data you do not hold cannot be breached.

Q356: Production Data in Test

Question

Developers use copies of production data in test environments with weaker controls. What is the BEST mitigation?

- (A) Apply the same password policy to test environments as to production, which brings their authentication in line
- (B) Allow the practice provided developers sign confidentiality agreements acknowledging the sensitivity of the data
- (C) Use masked, tokenized, or synthetic data in non-production, allowing production data only under approved and controlled exceptions
- (D) Restrict test environment access to one named developer, so that exposure of production data is limited to a single person

Q356: Explanation

Correct Answer: C

Why (C) is the best answer:

- Remove sensitivity from test data
- Exceptions require approval
- Controls should match data sensitivity

Critical Trap

Sensitive data in weak environments is a breach waiting to happen.

Q357: Ownerless Dataset

Question

A critical dataset has no assigned owner, and each team assumes someone else is responsible. What is the MOST significant risk?

- A Storage costs will rise, because unowned datasets cannot be archived or deleted without an approver
- B System performance will degrade, because unowned data is not tuned, indexed, or maintained
- C No one is accountable for classification, access decisions, quality, or retention, so risk goes unmanaged
- D Licensing fees will increase, because vendors charge more for datasets without a registered business owner

Q357: Explanation

Correct Answer: C

Why (C) is the best answer:

- Ownership drives decisions
- Access approvals need an owner
- Unowned data is unmanaged data

Critical Trap

Unowned data is unmanaged risk.

Q358: Conflicting Reports

Question

Reports from a data warehouse regularly conflict with source system figures. Which approach BEST addresses this?

- (A) Implement data quality controls and lineage tracing with reconciliation and ownership at each stage
- (B) Replace the business intelligence tool with a different product
- (C) Instruct users to rely only on the source system
- (D) Add more reports so users can cross-check them manually

Q358: Explanation

Correct Answer: A

Why (A) is the best answer:

- Trace data from source to report
- Reconcile at each stage
- Assign ownership of quality

Critical Trap

Trust in data comes from lineage and reconciliation.

Q359: Exiting a Cloud Provider

Question

How can an organization BEST ensure data is irrecoverable when exiting a cloud provider whose physical media it cannot inspect?

- A Ask the provider to delete the files and rely on its confirmation email as evidence of deletion
- B Overwrite the data once using the provider's management portal before closing the account
- C Use cryptographic erasure by destroying keys the organization controls, supported by contractual deletion obligations and evidence
- D Require physical destruction of the servers that stored the data, witnessed by the customer at the provider's data center

Q359: Explanation

Correct Answer: C

Why (C) is the best answer:

- Key destruction renders data unreadable
- Customer control of keys is essential
- Contracts require evidence of deletion

Critical Trap

When you cannot destroy the media, destroy the keys.

Q360: Cross-Border Processing

Question

A business wants to use a global analytics service that processes personal data in another region. What should be assessed FIRST?

- A Performance benchmarks of the analytics service, to confirm it can process the expected data volumes
- B Cost savings from regional pricing, to confirm the business case before any legal review begins
- C The legal basis and transfer mechanisms for cross-border processing, together with the provider's safeguards
- D Whether the data can be compressed before transfer, so that transmission cost and exposure are minimized

Q360: Explanation

Correct Answer: C

Why (C) is the best answer:

- Privacy law governs where data may go
- Transfer mechanisms must exist
- Evaluate provider safeguards

Critical Trap

Legality comes before performance.

Q361: DLP Bypass

Question

DLP generates many false positives, and users bypass it by using personal email. What is the BEST response?

- (A) Tune policies with business input, combine with user education, and address the workflow needs that cause users to seek alternatives
- (B) Disable DLP to improve productivity until the false-positive rate falls to an acceptable level
- (C) Increase blocking sensitivity so that fewer sensitive files can leave through any channel, including personal email
- (D) Replace DLP with a stronger perimeter firewall that blocks all external email destinations by default

Q361: Explanation

Correct Answer: A

Why (A) is the best answer:

- Tune policies with business input
- Educate users
- Fix the workflow need

Critical Trap

Controls that block work get bypassed.

Q362: Tokenization Versus Encryption

Question

Which statement BEST differentiates tokenization from encryption?

- A Tokenization is reversible using an encryption key held by the application, whereas encryption cannot be reversed once applied
- B Tokenization replaces data with surrogate values mapped in a secure vault, while encryption mathematically transforms data and is reversible with a key
- C Both are hashing techniques; they differ only in output format and are interchangeable for protecting regulated data
- D Tokenization always requires more computing power than encryption, which is why it is used only for small datasets

Q362: Explanation

Correct Answer: B

Why (B) is the best answer:

- Tokens have no mathematical relationship to data
- Vault mapping enables detokenization
- Encryption depends on key protection

Critical Trap

Tokens are substitutes; ciphertext is transformed data.

Q363: Erasure and Backups

Question

A data subject requests erasure, but the data also exists in backups that cannot be selectively modified. What is the BEST approach?

- (A) Refuse the request, because backups are always exempt from erasure rights under privacy regulations
- (B) Delete all backup sets immediately, so that complete erasure is guaranteed regardless of recovery consequences
- (C) Delete from live systems, document the backup limitation, ensure the data is not restored or used, and let it expire under the backup retention schedule
- (D) Ignore the request until a backup is next restored, then delete the data from the restored system

Q363: Explanation

Correct Answer: C

Why (C) is the best answer:

- Erase from active systems first
- Document technical limits
- Prevent use of backup copies

Critical Trap

Handle backup limits transparently, not by ignoring them.

Q364: Shadow Data

Question

Discovery tools find sensitive data in unmanaged file shares and personal cloud storage. What is the BEST action?

A. Delete all discovered data immediately, since unmanaged data has no business justification

B. Block all access to cloud storage services across the organization until a full inventory is completed

C. Accept the risk and issue a reminder, since users are responsible for the storage locations they choose

D. Inventory and classify the data, determine ownership, move or protect it under approved controls, and address the behaviors that created it

Q364: Explanation

Correct Answer: D

Why (D) is the best answer:

- Discover, classify, and assign owners
- Move data into controlled locations
- Fix the root behavior

Critical Trap

Discovery is the start, not the end.

Q365: Why Map Data

Question

Why is a data inventory and map foundational to data lifecycle risk management?

- (A) It replaces the need for classification, because location and flow information already indicate sensitivity
- (B) It is required only for backup planning, since other controls rely on classification rather than location
- (C) Controls, retention, privacy obligations, and incident response all depend on knowing where data resides and how it flows
- (D) It reduces the need for periodic access reviews, because the flows already show who uses each dataset

Q365: Explanation

Correct Answer: C

Why (C) is the best answer:

- You cannot protect unknown data
- Privacy obligations depend on flows
- Incident response needs data location

Critical Trap

You cannot manage data you cannot locate.

Q366: Sub-Processors

Question

A processor sub-contracts part of its service to another vendor that handles your customer data. Which control is MOST important?

- (A) No additional action is needed, because the primary vendor remains fully liable for its subcontractors
- (B) Ask the sub-vendor to sign a confidentiality agreement, which is sufficient assurance of protection
- (C) Require disclosure of the vendor's pricing and margin structure so that cost transparency is maintained across the chain
- (D) Contractual requirements for sub-processor approval and flow-down of security and privacy obligations, with the ability to assess compliance

Q366: Explanation

Correct Answer: D

Why (D) is the best answer:

- Obligations must flow down
- Approval rights over sub-processors
- Right to assess compliance

Critical Trap

Your obligations extend down the supply chain.

Q367: Inconsistent Retention

Question

Different departments keep data for varying periods with no consistent basis. What is the BEST approach?

- A Keep all data indefinitely to avoid any risk of noncompliance with retention obligations
- B Allow each data owner to choose a retention period based on the needs of their own department
- C Delete all data after one year to minimize exposure, regardless of legal or business requirements
- D Establish a retention schedule based on legal, regulatory, and business requirements with defined disposal procedures

Q367: Explanation

Correct Answer: D

Why (D) is the best answer:

- Retention must reflect obligations
- Schedule and disposal are linked
- Consistency supports compliance

Critical Trap

Retention is driven by requirements, not preference.

Q368: Long-Term Archives

Question

Archived records must remain readable and trustworthy for 15 years. Which risk is OFTEN overlooked?

- A Higher storage cost per gigabyte over time, which can make long-term archiving unaffordable
- B Backup window limitations, because long-term archives require additional nightly capacity
- C Network bandwidth constraints, which limit the speed at which archived records can be retrieved
- D Format and media obsolescence and loss of integrity or key access over time

Q368: Explanation

Correct Answer: D

Why (D) is the best answer:

- Formats and media become obsolete
- Keys must remain available
- Integrity must be verifiable

Critical Trap

Archives fail through obsolescence and lost keys.

Q369: Security Requirements Missing

Question

A project reaches testing and no security requirements were defined. What is the PRIMARY consequence?

- (A) Testers will have fewer test cases to execute, which will shorten the testing phase and the schedule
- (B) The project will automatically fail its next audit, because missing requirements are always an audit finding
- (C) Security gaps will be found late, when remediation is costlier and may be accepted under schedule pressure
- (D) Developers will be unable to use security tools, because those tools are configured from the requirements document

Q369: Explanation

Correct Answer: C

Why (C) is the best answer:

- Define requirements early
- Late fixes cost more
- Schedule pressure leads to acceptance

Critical Trap

Security requirements belong at the start.

Q370: SAST and DAST

Question

Which statement BEST describes how SAST and DAST complement each other?

A. SAST analyzes source code for flaws early, while DAST tests the running application for exploitable behavior, giving broader coverage together

B. SAST tests running applications and DAST analyzes source code, so both are needed to cover the full pipeline

C. They are redundant because each finds the same flaws, so one of them is sufficient for assurance

D. Both evaluate only infrastructure configuration and complement each other by covering different network layers

Q370: Explanation

Correct Answer: A

Why (A) is the best answer:

- SAST reviews code
- DAST tests the running application
- Together they cover more defects

Critical Trap

Static and dynamic testing find different flaws.

Q371: Unknown Library Exposure

Question

A critical vulnerability in an open-source library is announced. The organization cannot quickly tell which applications use it. What capability is MISSING?

- (A) A software bill of materials and dependency inventory to identify affected components
- (B) A larger security operations center, so that more analysts can search for the library across applications
- (C) Stronger network segmentation, so that vulnerable libraries cannot be reached from untrusted networks
- (D) Annual penetration testing, which would have identified the library as a vulnerable component

Q371: Explanation

Correct Answer: A

Why (A) is the best answer:

- You must know your components
- SBOM speeds impact assessment
- Supply chain visibility is a control

Critical Trap

If you cannot list your components, you cannot patch them.

Q372: Keys in Repository

Question

A scan finds API keys committed to a code repository. What is the BEST response?

- (A) Delete the commit from repository history, since the keys are then no longer accessible to others
- (B) Make the repository private, which restricts access to the keys to authorized staff
- (C) Warn developers by email not to repeat the practice and add the rule to the coding standard
- (D) Revoke and rotate the exposed credentials, then implement secrets management and pre-commit scanning

Q372: Explanation

Correct Answer: D

Why (D) is the best answer:

- Exposed credentials must be rotated
- Use a secrets manager
- Prevent recurrence with scanning

Critical Trap

Once exposed, a secret must be rotated.

Q373: Deferred Security in Agile

Question

In an agile project, security reviews and documentation are repeatedly deferred. What is the BEST way to address this?

A. Move the project to a waterfall approach, where security phases are fixed and cannot be skipped

B. Integrate security activities into sprints through the definition of done, automated checks, and risk-based acceptance criteria

C. Add a single security review at the end of the project to ensure that all issues are found before release

D. Remove documentation requirements entirely, to keep the team focused on delivering working software

Q373: Explanation

Correct Answer: B

Why (B) is the best answer:

- Make security part of done
- Automate checks in the pipeline
- Use risk-based criteria

Critical Trap

Agile needs security built in, not bolted on.

Q374: Self-Approved Code

Question

The developer who wrote a change also approves their own pull request. What control gap exists?

A. Insufficient unit test coverage, which allows defects to pass unnoticed through the pipeline

B. Inconsistent code style across the repository, which makes automated review less reliable

C. Lack of independent review, increasing the risk of errors or malicious code reaching production

D. Repository storage limits, which prevent reviewers from keeping a history of approvals

Q374: Explanation

Correct Answer: C

Why (C) is the best answer:

- Independent review catches errors
- Self-approval defeats segregation
- Enforce reviewer rules in tooling

Critical Trap

Nobody should approve their own work.

Q375: Developer-Run UAT

Question

User acceptance testing is performed by the same team that developed the application. What is the MAIN concern?

A. Developers will complete testing too slowly, because they must switch between development and testing roles

B. Lack of independence and business perspective reduces the likelihood of finding requirement or usability gaps

C. UAT must always use production data, which developers are not authorized to access

D. Documentation will be incomplete, because developers do not write test scripts for their own code

Q375: Explanation

Correct Answer: B

Why (B) is the best answer:

- UAT validates business need
- Independence adds objectivity
- Business users should execute UAT

Critical Trap

UAT belongs to the business.

Q376: Machine Learning Credit Model

Question

A bank deploys a machine learning credit decision model. Which governance element is MOST critical?

- (A) Training on the largest available dataset, since broader data always improves predictive performance and fairness
- (B) Model validation, ongoing monitoring for drift and bias, and clear accountability and explainability appropriate to the decisions
- (C) The reputation of the model vendor, since an established vendor's validation is sufficient assurance
- (D) Measuring accuracy once at launch, since a model that performs well initially will continue to do so

Q376: Explanation

Correct Answer: B

Why (B) is the best answer:

- Validate before and after deployment
- Monitor for drift and bias
- Assign accountability

Critical Trap

Models need governance across their whole life.

Q377: Training Data Manipulation

Question

Which risk is SPECIFIC to machine learning systems trained on external data?

- (A) Unauthorized access to the training environment through weak administrator passwords, a risk that applies equally to any system
- (B) Data poisoning, where manipulated training data degrades or biases model behavior
- (C) Injection of malicious SQL statements into the application database, a risk common to any web application
- (D) Memory corruption flaws in the operating system hosting the model, which exist regardless of the type of model

Q377: Explanation

Correct Answer: B

Why (B) is the best answer:

- Training data shapes behavior
- Attackers can corrupt inputs
- Validate data sources

Critical Trap

Model integrity depends on data integrity.

Q378: Generative AI Leakage

Question

Employees paste confidential code and customer data into a public generative AI tool. What is the BEST combination of controls?

- (A) Ban all generative AI tools through a policy statement, relying on employees to comply
- (B) Trust employees' judgment about what to share, supported by an annual reminder of confidentiality obligations
- (C) Rely on the AI vendor's terms of service, which state that submitted data is not used for training
- (D) Establish an acceptable use policy, provide approved AI tools with data protections, and use technical controls such as DLP and access restrictions

Q378: Explanation

Correct Answer: D

Why (D) is the best answer:

- Policy needs enforcement
- Offer a safe approved alternative
- Use DLP to stop leakage

Critical Trap

Provide a safe path and enforce it.

Q379: Default Credentials on IoT

Question

A manufacturer deploys thousands of IoT sensors with default credentials and no update mechanism. What is the MOST significant risk?

- (A) Unmanaged, easily compromised devices that provide network entry points and cannot be patched
- (B) Increased electricity consumption across the plant, which raises operating costs
- (C) Data format incompatibility with analytics tools, which prevents collected data from being used
- (D) Gradual drift in sensor accuracy, which reduces the quality of production data over time

Q379: Explanation

Correct Answer: A

Why (A) is the best answer:

- Default credentials are well known
- Unpatchable devices stay vulnerable
- Segment and inventory devices

Critical Trap

Unmanageable devices are permanent entry points.

Q380: Smart Contract Deployment

Question

Before deploying a smart contract that manages financial assets, which activity is MOST important?

- (A) A marketing campaign to attract users, since adoption determines the contract's success
- (B) Independent code audit and extensive testing, since deployed code may be immutable and flaws irreversible
- (C) Raising transaction fees so that the contract executes with priority on the network
- (D) Selecting a faster block time, so that transactions confirm sooner and fraud is detected earlier

Q380: Explanation

Correct Answer: B

Why (B) is the best answer:

- Deployed code is hard to change
- Audit before release
- Test edge cases thoroughly

Critical Trap

Immutable code demands pre-release assurance.

Q381: Low-Code Sprawl

Question

Business users build workflows with low-code tools that connect to sensitive data without IT involvement. What is the BEST governance response?

A. Provide a governed platform with guardrails, an inventory, data access controls, and review for higher-risk applications

B. Prohibit all low-code development and require requests to go through the standard IT project process

C. Allow users to self-certify the security of their applications through an annual questionnaire

D. Require IT to build every workflow, so that all applications follow the standard development lifecycle

Q381: Explanation

Correct Answer: A

Why (A) is the best answer:

- Offer a governed platform
- Maintain an inventory
- Review by risk level

Critical Trap

Enable citizen developers safely.

Q382: Bot Credentials

Question

Robotic process automation bots log into multiple systems using a shared admin account. What is the BEST improvement?

- (A) Increase the length and complexity of the shared password and rotate it quarterly
- (B) Assign unique, least-privilege bot identities with credentials in a vault, logging, and a named owner
- (C) Run bots only during overnight windows when fewer users are active, to reduce exposure
- (D) Remove bot logging to improve performance, since bot actions are already predictable

Q382: Explanation

Correct Answer: B

Why (B) is the best answer:

- Bots need unique identities
- Vault the credentials
- Log bot actions

Critical Trap

Bots are identities and need least privilege.

Q383: Unscanned Container Images

Question

Containers are built from public base images with no scanning. What is the PRIMARY risk?

A. Slower container startup times, because public images are larger than curated internal images

B. Higher licensing fees, because public images carry commercial license obligations

C. Increased network traffic, because images must be pulled from external registries on every deployment

D. Inherited vulnerabilities or malicious components in public base images are deployed at scale across every container built from them

Q383: Explanation

Correct Answer: D

Why (D) is the best answer:

- Base images can be vulnerable
- Scan images in the pipeline
- Use trusted registries

Critical Trap

Scan what you build from.

Q384: Exposed APIs

Question

Which is the MOST important control for externally exposed APIs?

A. Strong authentication and authorization on each request, with input validation and rate limiting

B. Obscure URL paths that are hard to guess, so that only intended consumers discover the API

C. Keeping the API documentation hidden from the public, so that attackers cannot learn how the API works

D. Running the API on a non-standard port, so that automated scanners do not detect it

Q384: Explanation

Correct Answer: A

Why (A) is the best answer:

- Authenticate and authorize every call
- Validate input
- Rate limit to resist abuse

Critical Trap

Obscurity is not authorization.

Q385: Crypto Agility

Question

Why should organizations consider cryptographic agility in light of quantum computing?

A. Because quantum computing makes hashing impossible, so all integrity controls must be replaced immediately

B. To replace vulnerable algorithms without major redesign, since long-lived confidential data may be harvested now and decrypted later

C. Because quantum computers will make symmetric encryption trivially breakable, so all data must be re-encrypted this year

D. Because all current systems are already quantum-safe, so only governance of algorithm choices is needed

Q385: Explanation

Correct Answer: B

Why (B) is the best answer:

- Algorithms may need replacement
- Harvest now, decrypt later is a risk
- Design for replaceable crypto

Critical Trap

Plan for algorithm change before it is forced.

Q386: Access Accumulation

Question

An employee has transferred departments three times and retains access from every previous role. Which control would have BEST prevented this?

A. Access review triggered by role change, plus periodic recertification by business owners

B. Stronger password complexity requirements, which would reduce the chance that old accounts are misused

C. Annual security awareness training, which would remind employees to surrender access they no longer need

D. Single sign-on across applications, which would make it easier to remove access from one place

Q386: Explanation

Correct Answer: A

Why (A) is the best answer:

- Role change must trigger review
- Owners recertify access
- Prevents privilege accumulation

Critical Trap

Access must follow the role, not the history.

Q387: Privileged Access

Question

Which privileged access management capability BEST reduces risk from compromised administrator credentials?

- (A) Longer and more complex passwords for administrator accounts, changed at each employee departure
- (B) Shared administrator accounts with scheduled rotation of passwords every thirty days
- (C) Just-in-time privileged access with credential vaulting and session recording
- (D) Email notification to the security team of every administrator login, reviewed weekly

Q387: Explanation

Correct Answer: C

Why (C) is the best answer:

- Limit standing privileges
- Vault credentials
- Record sessions for accountability

Critical Trap

Reduce standing privilege and record what is done.

Q388: Push Bombing

Question

Attackers bombard users with push approval requests until one is accepted. What is the BEST mitigation?

- (A) Disable push-based MFA and rely on strong passwords, since fatigue attacks target only the approval step
- (B) Increase password length requirements so that stolen credentials are insufficient on their own
- (C) Switch from push approvals to SMS one-time codes, which are not susceptible to repeated prompts
- (D) Phishing-resistant MFA or number matching, with rate limiting and user reporting

Q388: Explanation

Correct Answer: D

Why (D) is the best answer:

- Prompt fatigue is an attack method
- Use number matching or FIDO
- Rate limit and report

Critical Trap

MFA must resist social engineering.

Q389: Zero Trust Principle

Question

Which statement BEST reflects zero trust implementation?

A. Users are trusted after VPN login because they are on the internal network

B. A next-generation firewall at the perimeter provides sufficient protection

C. MFA is required once per year for all employees

D. Access is decided per request using identity, device posture, and context, with least privilege and continuous verification

Q389: Explanation

Correct Answer: D

Why (D) is the best answer:

- Never trust by location
- Verify identity, device, and context
- Apply least privilege continuously

Critical Trap

Location is not trust.

Q390: Keys Beside Data

Question

Encryption keys are stored on the same server as the encrypted data. What is the MAIN issue?

A. System performance will degrade, because decryption on the same server consumes additional processing capacity

B. Compromise of the server exposes both data and keys, defeating the protection; keys should be separately protected, for example in an HSM or KMS

C. Keys will expire sooner when stored on production servers, causing frequent encryption failures

D. Regulations prohibit encryption on application servers, so data must be encrypted in the database tier only

Q390: Explanation

Correct Answer: B

Why (B) is the best answer:

- Keys must be separate from data
- Use HSM or KMS
- Control key access tightly

Critical Trap

Encryption is only as strong as key protection.

Q391: Defense in Depth

Question

Which design BEST demonstrates defense in depth for a sensitive database?

A. One very strong perimeter firewall with advanced threat detection, which blocks attacks before they reach the database

B. Multiple identical firewalls in series, so that a failure in one is covered by the next

C. Layered controls including segmentation, access control, encryption, monitoring, and backups

D. Strong complex passwords on all database accounts, changed regularly and stored in a vault

Q391: Explanation

Correct Answer: C

Why (C) is the best answer:

- Multiple layers of control
- Different control types
- One failure does not expose the asset

Critical Trap

No single control should stand alone.

Q392: Premature Eradication

Question

During an active intrusion, the team wants to immediately wipe and rebuild affected servers. What is the concern?

A. Rebuilding is always preferred to investigation, since it removes the attacker immediately and limits further damage

B. Premature eradication may destroy forensic evidence and miss attacker persistence if scope is not understood; containment and investigation come first

C. Wiping servers violates cloud service terms, which prohibit customers from destroying provider-managed resources

D. Servers cannot be rebuilt during business hours, so the activity must wait for the next maintenance window

Q392: Explanation

Correct Answer: B

Why (B) is the best answer:

- Contain first
- Preserve evidence
- Understand scope before eradicating

Critical Trap

Investigate scope before you eradicate.

Q393: Vulnerability Prioritization

Question

Thousands of vulnerabilities exist. What is the BEST prioritization approach?

- (A) Prioritize strictly by CVSS base score, since it is the standardized and objective measure of severity
- (B) Risk-based prioritization using exploitability, asset criticality, exposure, and compensating controls, not CVSS alone
- (C) Remediate the oldest vulnerabilities first, since they have been exposed to attackers for the longest time
- (D) Remediate the easiest vulnerabilities first, so that the largest number of findings are closed quickly

Q393: Explanation

Correct Answer: B

Why (B) is the best answer:

- Combine exploitability and impact
- Consider asset criticality
- Account for compensating controls

Critical Trap

Severity scores need business context.

Q394: Awareness Effectiveness

Question

Which metric BEST shows the effectiveness of security awareness training?

A. Behavior metrics such as phishing report rates and declining click rates over time

B. Training completion percentage, which shows that the workforce has been reached by the program

C. Total hours of training delivered, which indicates the depth of the awareness program

D. Average quiz scores after the course, which show that employees have retained the material

Q394: Explanation

Correct Answer: A

Why (A) is the best answer:

- Measure behavior change
- Reporting indicates engagement
- Completion is not effectiveness

Critical Trap

Measure behavior, not attendance.

Q395: SIEM Without Use Cases

Question

A SIEM collects logs from many sources, but no detection use cases are defined. What is the MAIN weakness?

- A Storage costs will exceed budget, because logs from all sources are retained without selection
- B Log formats will be inconsistent, which prevents correlation across sources
- C Analysts will need additional certification, because the platform cannot be used without vendor-specific training
- D Collected data is not turned into detection of relevant threats; use cases aligned with risk scenarios are needed

Q395: Explanation

Correct Answer: D

Why (D) is the best answer:

- Logs alone do not detect
- Align use cases to risk scenarios
- Tune continuously

Critical Trap

A SIEM without use cases is an expensive archive.

Q396: Exposed Cloud Bucket

Question

A company's IaaS storage bucket is publicly exposed due to a misconfiguration. Who is MOST likely responsible?

A. The cloud provider in every case, since it operates the platform that hosts the storage service

B. Both parties equally, regardless of the service model, since responsibility is always split evenly under the shared responsibility model

C. The regulator that certified the provider, since certification implies that default configurations are secure

D. The customer, since configuring access controls on its own data is the customer's responsibility under shared responsibility

Q396: Explanation

Correct Answer: D

Why (D) is the best answer:

- Customers configure their own access
- Providers secure the infrastructure
- Misconfiguration is a leading cloud risk

Critical Trap

Shared responsibility does not remove customer duties.

Q397: Insider Threat

Question

Which combination BEST mitigates insider threat?

- (A) Background checks at hiring, repeated every few years, which screen out most malicious individuals
- (B) A very strict network perimeter that blocks all unauthorized external access
- (C) Least privilege, monitoring for anomalous behavior, segregation of duties, and HR-integrated onboarding and offboarding
- (D) Prohibiting personal devices in the workplace so that data cannot be copied out of the organization

Q397: Explanation

Correct Answer: C

Why (C) is the best answer:

- Limit access to what is needed
- Monitor behavior
- Coordinate with HR at joiner, mover, leaver

Critical Trap

Insider risk needs layered, people-centered controls.

Q398: Limited Pen Test Scope

Question

A penetration test excluded the most critical systems to avoid disruption. What is the MAIN implication?

- (A) The test is more reliable, because it avoided disruption and therefore produced cleaner results
- (B) Critical systems are automatically secure, since they are subject to stricter change control
- (C) The organization saved cost with no impact on risk, because the tested systems are representative of those excluded
- (D) Assurance does not cover the highest-risk assets, so a controlled testing approach for them should be designed

Q398: Explanation

Correct Answer: D

Why (D) is the best answer:

- Scope determines assurance
- Critical assets need testing
- Use safe, controlled methods

Critical Trap

Do not skip the assets that matter most.

Q399: Access Management KRI

Question

Which is the BEST key risk indicator for access management?

A. Number of password resets performed, which indicates the burden on the help desk

B. Total number of users in the directory, which indicates the size of the attack surface

C. Percentage of privileged accounts not recertified within policy, and number of orphaned accounts

D. Number of help desk calls related to access, which indicates user satisfaction with access processes

Q399: Explanation

Correct Answer: C

Why (C) is the best answer:

- KRIs show risk trends
- Privileged accounts are high risk
- Orphaned accounts show process failure

Critical Trap

A KRI measures risk exposure, not activity.

Q400: Log Tampering

Question

Administrators can edit the logs on the systems they manage. Which control is MOST appropriate?

A. Ask administrators to confirm in writing that they will not alter logs, and review the confirmation annually

B. Forward logs in near real time to a centralized, access-restricted, tamper-evident repository

C. Reduce log verbosity so that less information is available that can be edited

D. Print logs weekly and file them for manual review by the internal audit function

Q400: Explanation

Correct Answer: B

Why (B) is the best answer:

- Logs must be independent of admins
- Centralize and restrict access
- Tamper evidence supports investigations

Critical Trap

Logs controlled by those they record are not reliable evidence.

Exam Mindset Summary

Remember

- **Judgment over trivia:** pick the action that best manages risk for the business
- **Governance first:** exceptions, deviations, and trade-offs need documented decisions by accountable owners
- **Know the dependency:** resilience, vendors, and shared services must match what depends on them
- **Test, do not assume:** restores, rollbacks, and compensating controls need evidence
- **Contain before you eradicate** and preserve evidence
- **Least privilege and independence:** no self-approval, no shared credentials
- **Data:** know where it is, who owns it, how long to keep it, and how to destroy it
- **Security is continuous risk management**

Thank You

Good Luck on Your CRISC Exam!